

MikroTik Firewall and VPN

A complete beginner's big-picture guide

How a virtual router protects traffic, how VPN encryption fits in, what we have built in UTM, and what the finished security lab should become.

The central idea

A firewall can only inspect and protect traffic that actually passes through it. Our VM is the security appliance; the next step is to make it the required path between a protected network and an untrusted network.

Prepared for the MikroTik CHR lab running in UTM on Apple Silicon.

Contents

- | | |
|-----------|--|
| 1 | The goal and the security-gateway idea |
| 2 | What we built: Mac, UTM, CHR, and virtual hardware |
| 3 | How network traffic and firewall decisions work |
| 4 | RouterOS firewall paths: input, forward, and output |
| 5 | NAT: address translation versus security |
| 6 | VPNs: encryption, authentication, and tunnel designs |
| 7 | How the firewall and VPN work together |
| 8 | What the current VM can and cannot protect |
| 9 | The finished two-interface security lab |
| 10 | A safe implementation and testing roadmap |
| 11 | Glossary and current lab details |

How to read this guide

Read sections 1-8 first for the concepts. Sections 9-10 describe the practical destination and the safest order of work.

1. The goal: a virtual security gateway

The goal is not merely to run MikroTik software. The goal is to create a security checkpoint that controls traffic and provides encrypted VPN access.



When MikroTik sits in the path, RouterOS can inspect each connection, allow legitimate activity, block unwanted traffic, translate addresses with NAT, log suspicious events, and send selected traffic through an encrypted VPN tunnel.

The non-negotiable principle

Traffic must pass through MikroTik

Simply having RouterOS running does not protect your Mac or other devices. The protected device must use MikroTik as its gateway, or deliberately send traffic into MikroTik through a VPN.

What a finished system should do

- Protect RouterOS itself from unauthorized management access.
- Protect devices behind MikroTik from unsolicited inbound connections.
- Control which outbound connections protected devices may create.
- Authenticate VPN users and encrypt their traffic.
- Limit VPN users to only the internal resources they actually need.
- Record important allowed and blocked activity for troubleshooting.

2. What we built

We created a virtual MikroTik router instead of buying physical router hardware. Each layer has a specific job.

Layer	Purpose
Apple Silicon Mac	The physical computer supplying real CPU, memory, storage, and networking.
UTM	The virtual-machine application that creates and manages the virtual hardware.
QEMU	The engine UTM uses to emulate the ARM64 computer seen by RouterOS.
MikroTik CHR	Cloud Hosted Router: RouterOS packaged to run as a virtual router.
CHR disk image	The virtual hard drive containing the RouterOS kernel, services, configuration, WebFig, SSH, and WinBox.

The virtual hardware

- ARM64 architecture, matching the Apple Silicon host and MikroTik ARM64 image.
- Two virtual CPU cores and 2 GiB of RAM.
- UEFI firmware to locate and start RouterOS from its system disk.
- One non-removable VirtIO system disk containing RouterOS.
- One virtio-net-pci Ethernet adapter connected to UTM shared/NAT networking.
- One PTTY serial console for boot diagnostics and emergency recovery.
- No graphical display and no sound, because a router is managed remotely.

Compatibility result

Apple Hypervisor acceleration caused RouterOS 7.22.1 ARM64 to panic during boot. Software emulation was left enabled because it reaches the RouterOS login prompt and works reliably. VirtIO storage itself works.

3. How a firewall sees traffic

Network information is broken into small units called packets. A packet carries facts the firewall can examine: source address, destination address, protocol, port, incoming interface, and connection state.

Packet field	Example	Meaning
Source	192.168.10.20	The device that sent the packet.
Destination	1.1.1.1	Where the packet is going.
Protocol	TCP	The communication method.
Destination port	443	Usually an HTTPS web connection.
State	new	The connection is being started.

Stateful firewalling

RouterOS remembers active connections. This lets it distinguish a legitimate reply from an unexpected new connection.

- **new:** A device is trying to begin a connection.
- **established:** The packet belongs to a connection already accepted.
- **related:** The packet is connected to another legitimate connection.
- **invalid:** RouterOS cannot correctly associate or validate the packet.

A common safe pattern

Allow established and related traffic, drop invalid traffic, carefully allow necessary new connections, then block traffic that was not explicitly allowed.

Rule order matters

RouterOS normally checks firewall rules from top to bottom. A broad allow rule placed too early can bypass more specific block rules below it. Clear ordering is part of the security design.

4. The three important firewall paths

Path	Traffic	What it protects
INPUT	Traffic addressed to MikroTik itself: WebFig, WinBox, SSH, VPN handshakes, and ping.	The router and its management services.
FORWARD	Traffic passing through MikroTik between networks or VPN users and internal systems.	Devices and networks behind the router.
OUTPUT	Traffic created by MikroTik: update checks, DNS, logging, or an outbound VPN connection.	What the router itself may contact.

Example: opening a website



The computer starts an outbound connection. MikroTik records it, allows it according to the forward policy, and performs NAT. The website's reply is recognized as established traffic and is returned to the correct computer.

Example: an unexpected inbound attempt



There is no existing approved connection. Unless a deliberate inbound service rule exists, the firewall should block the attempt before it reaches the protected computer.

Management protection

The INPUT policy should allow WebFig, WinBox, and SSH only from trusted networks. A WAN interface should not expose administration services to everyone.

5. NAT is not the firewall

NAT means Network Address Translation. It changes addressing so private devices can share the router's outward-facing connection.



When a response returns, MikroTik uses connection tracking to send it back to the correct private device.

NAT	Firewall
Changes source or destination addresses and sometimes ports.	Allows, rejects, drops, logs, or limits traffic.
Makes private addresses usable behind a shared outward address.	Enforces the security policy between networks.
Does not replace deliberate access-control rules.	Should explicitly control new inbound and outbound connections.

Remember

NAT answers 'which address should appear on this packet?' The firewall answers 'should this packet be allowed at all?' A secure gateway normally uses both.

Default-deny philosophy

A strong policy begins by allowing known legitimate needs, then denies traffic that has not been approved. This is safer than trying to predict and list every possible dangerous connection.

6. What a VPN adds

A Virtual Private Network creates an encrypted tunnel through an untrusted network. It protects the contents of traffic while it travels and authenticates the tunnel endpoints.



- **Encryption:** Outsiders should not be able to read the protected information inside the tunnel.
- **Authentication:** Each side proves its identity using keys, credentials, or certificates.
- **Integrity:** Unauthorized changes to tunneled traffic can be detected.

A VPN does not replace a firewall

The VPN decides whether a secure tunnel may be established. The firewall decides what the authenticated VPN user may access after connecting.

Three common VPN designs

Remote access	A laptop or phone connects securely back to MikroTik while the user is away.
Site to site	Two remote networks are joined through an encrypted tunnel between gateways.
VPN client gateway	MikroTik sends selected protected-device traffic through another VPN server or provider.

7. Firewall and VPN working together

Imagine that you are away from home and need to reach a private server. The complete process is:

- 1. Your laptop contacts the MikroTik VPN service.
- 2. MikroTik verifies the laptop's VPN identity and keys.
- 3. An encrypted tunnel is established.
- 4. The laptop receives a private VPN address.
- 5. Traffic enters RouterOS through the VPN interface.
- 6. Firewall rules decide which internal systems and services are allowed.
- 7. Allowed traffic is forwarded; unauthorized traffic is blocked and may be logged.
- 8. Responses return through the encrypted tunnel.



Least privilege

A VPN user should not automatically receive unrestricted access to every internal system. The safer approach is to grant only the networks, servers, and ports required for that user's purpose.

Two separate questions

VPN: 'Is this user or device authenticated, and is the path encrypted?' Firewall: 'Now that it is connected, exactly what may it reach?'

WireGuard as a learning choice

WireGuard is often a good modern starting point because its design is comparatively small: each peer has keys, tunnel addresses, and explicitly allowed IP ranges. Even with WireGuard, routing and firewall policy still need to be designed correctly.

8. What the current VM can and cannot protect

What is already working

- RouterOS 7.22.1 boots and reaches its login prompt.
- The VM is reachable from the Mac at 192.168.64.2.
- WebFig on port 80, SSH on port 22, and WinBox on port 8291 are reachable.
- The serial console provides a recovery path if network access is broken.
- RouterOS is ready for firewall and VPN configuration.

The current limitation

The VM currently has one virtual Ethernet adapter. It is connected to UTM's shared/NAT network. That is enough to manage RouterOS and learn its features, but it does not automatically place your Mac's normal internet traffic behind the MikroTik firewall.

Why one interface is limited

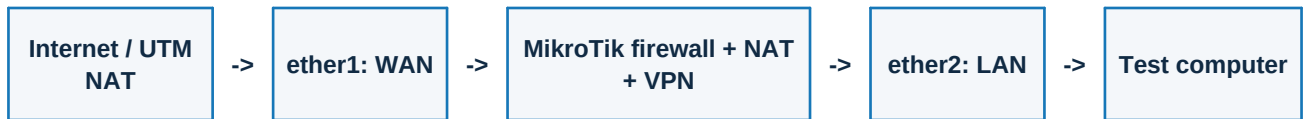
A traditional gateway needs an untrusted side and a protected side. With only one interface, there is not yet a separate LAN behind MikroTik through which ordinary client traffic must pass.

Two ways to make protection real

Gateway design	Add a second MikroTik interface and place a test computer or VM behind it. That client uses MikroTik as its default gateway, so its traffic must pass through the firewall.
VPN-path design	Connect a device to MikroTik through a VPN and route selected traffic into the tunnel. MikroTik then filters that VPN traffic.

9. The finished two-interface lab

The most educational next design is a small, isolated two-sided network.



Interface roles

- **ether1 - WAN:** connected to UTM's shared/NAT network; treated as untrusted.
- **ether2 - LAN:** connected to an isolated virtual network; treated as protected.
- **Test computer:** connected only to the protected LAN and configured to use MikroTik as its default gateway.

Example packet journey

1. The test computer asks to open a website.
2. The packet arrives on MikroTik's LAN interface.
3. RouterOS checks connection tracking and forward firewall rules.
4. If allowed, RouterOS performs NAT and sends the packet through the WAN interface.
5. The reply returns to MikroTik.
6. RouterOS recognizes it as established traffic and returns it to the test computer.

Why this is a safe lab

The protected LAN is virtual and isolated. You can learn routing, NAT, firewall rules, logging, and VPN access without immediately replacing your real home router.

What the firewall would enforce

- Allow required LAN-to-internet connections.
- Block unsolicited WAN-to-LAN connections.
- Restrict management to trusted LAN or VPN addresses.
- Permit only approved VPN-to-LAN access.
- Log selected denied connections without flooding the logs.

10. Safe implementation roadmap

1. Secure management	Set a strong password, create a separate administrator, restrict management services to trusted sources, and back up the configuration.
2. Add the protected LAN	Add a second virtual adapter, define WAN and LAN roles, assign a LAN address, and provide DHCP to a test client.
3. Build the firewall	Allow established/related traffic, drop invalid traffic, protect INPUT, control FORWARD, then add a final default deny.
4. Configure NAT	Translate protected LAN addresses for internet access and verify replies return correctly.
5. Configure the VPN	Create keys, tunnel addresses, peers, allowed IP ranges, routes, and tightly scoped firewall access.
6. Test from both sides	Verify allowed traffic works, blocked traffic fails, management is restricted, VPN access is encrypted, and logs are useful.
7. Reboot and retest	Confirm the VM starts cleanly and the complete policy survives a restart.

Why incremental changes matter

A firewall mistake can lock you out, break DHCP or DNS, or expose a service. Add and test small groups of rules. Keep serial-console recovery available until the final policy is proven.

A sensible first test

Use a disposable test VM behind the MikroTik LAN. Confirm it can obtain an address, reach allowed destinations, cannot receive unexpected inbound connections, and can reach only the management or VPN resources you intentionally permit.

11. Glossary and current lab details

CHR	Cloud Hosted Router; RouterOS packaged for virtual machines.
Firewall	Rules that decide whether network traffic is allowed, blocked, rejected, limited, or logged.
Gateway	The router a device sends traffic to when the destination is outside its local network.
WAN	The untrusted or outward-facing network side.
LAN	The trusted or protected local-network side.
NAT	Address translation, commonly used to let private devices share an outward address.
VPN	An authenticated and encrypted tunnel through an untrusted network.
Packet	A small unit of network data carrying addresses, protocol, ports, and content.
Port	A numbered endpoint associated with a network service, such as SSH port 22.
Connection tracking	RouterOS memory of active connections and their states.
Default deny	Block traffic unless a rule explicitly allows it.
Least privilege	Grant only the access needed for a specific purpose.

Current MikroTik lab

VM name	MikroTik CHR Automated
RouterOS	7.22.1 stable, ARM64
Management IP	192.168.64.2 on UTM's private shared/NAT network
WebFig	http://192.168.64.2
Other access	SSH port 22, WinBox port 8291, serial /dev/ttyS000 while running
Current topology	One Ethernet adapter; ready for management and learning, not yet a two-sided gateway

Final takeaway

We have built and verified the security appliance. The next major step is to build the traffic path around it: WAN -> MikroTik firewall/VPN -> protected LAN. Only then does MikroTik become the required checkpoint for client traffic.